

【일련번호 8】

감사결과 처분요구서

【부 서 명】 화순병원 방사선종양학과, 화순병원 의공학과, 본원 정보보호실
【처 분 종 류】 개선
【제 목】 원격접속시스템 도입 시 개인정보 및 보안 관리 필요

【감 사 사 항】

1. 업무 개요

원격접속시스템은 외부에서 병원 내부망 또는 특정 장비에 접근하여 시스템 점검 및 기술지원, 의료데이터 활용을 목적으로 운영하고 있으며, 이 과정에서 접속 권한 부여, 작업 범위 설정, 수행 이력 관리 등 일련의 정보관리 절차가 수반된다. 특히 의료 장비는 시스템 안정성과 연속성이 매우 중요하며, 동시에 환자의 진료정보 및 치료계획 데이터 등 민감 정보와 연계되어 있어 접근통제 및 정보보호 관리가 필수적으로 요구된다.

2. 관계 법령(판단기준)

「개인정보보호법」 제26조(업무위탁에 따른 개인정보의 처리 제한)에 의거 개인정보처리자가 제3자에게 개인정보의 처리 업무를 위탁하는 경우에는 위탁업무 수행 목적 외 개인정보의 처리 금지, 개인정보의 기술적·관리적 보호조치에 관한 사항 등의 내용이 포함된 문서로 하여야 한다고 규정하고 있으며, 「ISMS인증규정」 2. 보호대책 요구사항에는 외부자 현황관리, 계약 시 보안, 보안 이행 관리 등 외부자 보안에 대한 관리 사항을 정하고 있다.

3. 감사결과 확인된 문제

감사일 현재 원격접속시스템 운영 및 정보관리 현황을 점검한 결과, 외부협력업체가 우리병원 시스템에 접속하여 장비를 포맷, 점검, 업데이트가 가능하도록 하면서 장비 도입, 유지보수 및 운영 계약서 상 외부접속 범위, 데이터 처리 방식 등이 포함되지 않았고, 외부협력업체 등록 시 전임의가 원격접속신청을 하도

록 정보보호실에서는 안내하고 있음에도 일반직 직원이 관련 업무를 수행하고 있음을〔표7〕과 같이 확인하였다.

〔표7〕 원격접속시스템 운영 및 정보관리 현황

외부업체	외부업체 담당	계정생성	최종 연장신청	신청담당	원격접속 신청 목적	비고

※ 원격접속신청서 : 개인정보 및 보안위원회 결정에 따라 전임의 이상만 신청 가능

4. 판단요지

병원 내 원격접속시스템은 외부협력업체 및 내부 담당자가 의료장비 유지보수, 시스템 점검, 소프트웨어 업데이트와 의료진의 의료데이터 활용을 원활히 할 수 있도록 지원하기 위해 정보보호실의 통제에 의해 운영되고 있다.

특히 외부협력업체가 원격접속시스템에 의해 우리병원 전산망에 접속하여 의료장비의 포맷, 점검, 패치 및 업그레이드 등의 작업을 수행하는 형태로 이루어 지는데, 그 과정에서 시스템 접근 권한 부여, 접속 승인, 작업 수행 및 종료에 이르는 일련의 절차가 수반된다. 더욱이 원격작업과정에서 환자정보 및 진료정보 등 민감정보에 접근할 가능성이 존재함에 따라, 이에 대한 접근통제 및 정보보호 관리가 중요하게 요구된다.

이에 따라 병원에서는 외부협력업체의 원격접속을 관리하기 위하여 사전 등록 및 승인 절차를 운영하고 있으며, 정보보호실을 중심으로 외부접속 계정 발급, 권한 설정, 접속 이력 관리 등의 업무를 수행하고 있다. 아울러 유지보수 계약을 통해 외부업체의 업무 범위 및 책임사항을 규정하고, 시스템 운영의 안정성과 보안성을 확보하고자 노력하고 있다.

한편, 원격접속은 물리적 통제가 제한된 환경에서 이루어지는 특성상 접근 권한 관리, 접속 범위 설정, 작업 이력 기록, 데이터 처리 통제 등 다양한 관리요소

가 복합적으로 작용하는 영역으로, 체계적인 운영 기준과 내부통제 절차의 준수가 필수적인 바, 원격접속시스템 운영 및 정보관리 현황에 대한 점검을 위한 시스템 운영 상태 뿐만 아니라 정보보호, 법적 준수, 책임관리 체계를 엄격히 검토하여 실행해야 한다.

그럼에도 불구하고 이번 방사선종양학과 감사과정에서 원격접속에 대한 범위, 접근 권한, 데이터 처리 방식 등 핵심적인 사항이 유지보수 및 운영 계약서에 명확히 반영되어 있지 않았음을 확인하였다.

우리병원은 환자의 민감한 개인정보 및 진료정보를 처리하는 기관으로서 「개인정보 보호법」 및 「의료법」에 따라 개인정보 보호에 관하여 엄격하게 관리하여 하며, 특히 외부협력업체에 의한 시스템 접근이 이루어지는 경우에는 접속 범위, 목적, 처리 정보의 종류, 보안조치 및 책임소재 등을 계약서에 명확히 규정하여 운영할 필요가 있다.

현재와 같이 계약서상 관련 내용이 없는 상태에서 외부업체가 시스템 접근 과정에서 개인정보를 열람하거나 유출하는 사고가 발생할 경우, 병원은 관리·감독 의무를 다하지 못한 것으로 판단되어 법적 책임에서 자유로울 수 없게 된다. 또한 원격접속을 통해 수행되는 작업 과정에서 장애 발생, 데이터 훼손, 시스템 오류 등이 발생할 경우, 해당 책임이 병원에 있는지 외부업체에 있는지에 대한 구분이 계약상 명확히 규정되어 있지 않아 분쟁 발생 시 책임 귀속이 불명확해질 우려가 있을 수 있어 외부협력업체의 정보처리에 관한 절차를 명확히 규정할 필요가 있다.

다음으로 외부협력업체의 시스템 접근과 관련하여 정보보호실에서 정한 등록 및 승인 절차가 존재함에도 불구하고, 실제 운영 과정에서는 전임의가 아닌 일반 직원이 협력업체 등록을 신청하고 있는 사례가 확인되어 내부 통제 절차가 제대로 준수되지 않고 있음을 확인하였다.

원격접속과 같이 외부협력업체에 시스템 접근 권한을 부여하는 업무는 환자 정보 및 병원 핵심 시스템과 직결되는 고위험 영역에 해당하므로, 단순한 편의성보다 적절한 통제 절차의 준수가 우선되어야 한다. 만일 업무 효율성 측면에서 의료진이 직접 신청서를 작성하는 것이 현실적으로 어렵다면 신청 절차의 일부를 보완하거나 전산화 등을 통한 개선방안이 요구된다.

【처 분 요 구】

화순전남대학교병원장은 원격접속시스템 운영과 관련하여 유지보수 및 운영 계약서에 명확히 반영하도록 하여야 하며, 의료진이 아닌 일반 직원이 협력업체 등록을 신청하고 있는 부분을 개선하여 주시기 바랍니다.**(개선-화순병원 방사선종양학과, 통보-화순병원 의공학과, 본원 정보보호실)**